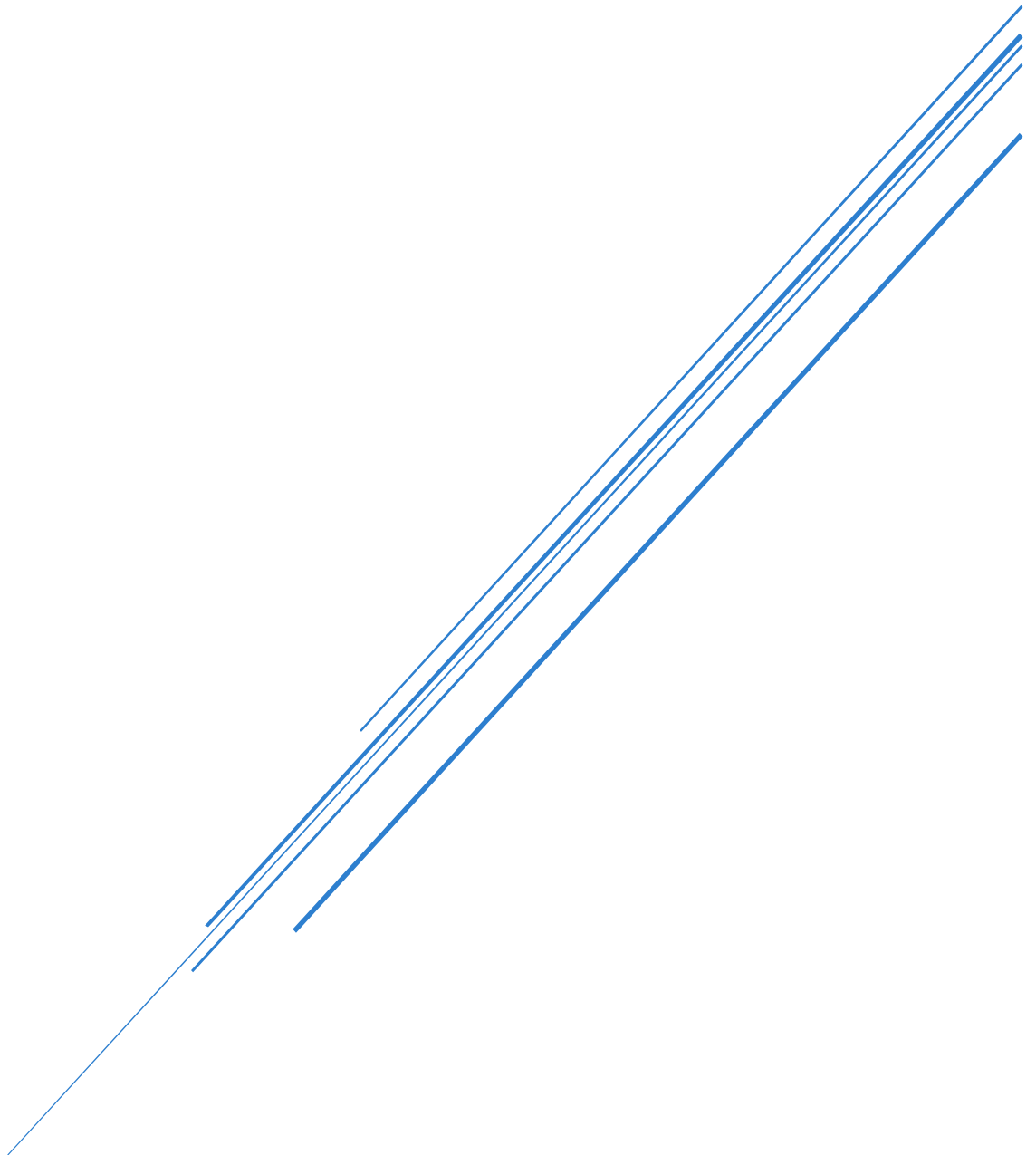


TECHCO - PLAN FORMAL DE RESPUESTA A INCIDENTE DE RANSOMWARE

Basado en el Marco de Ciberseguridad del NIST
(National Institute of Standards and Technology)



David Alonso Montero
20/05/2025

Resumen Ejecutivo

Este documento presenta el Plan Formal de Respuesta a Incidente de Ransomware desarrollado para la empresa ficticia TechCo, cuya actividad principal es la prestación de servicios en la nube y la gestión de datos confidenciales de clientes. Tras un incidente de ransomware originado por un correo electrónico de phishing, la organización ha sufrido la interrupción crítica de sus operaciones, comprometiendo sus servidores de archivos, base de datos de clientes y sistemas de respaldo.

El plan se estructura conforme al Marco de Ciberseguridad del NIST, abordando cinco funciones clave: Identificación, Protección, Detección, Respuesta y Recuperación. A través de este marco, se propone un enfoque integral y escalable que refuerce la postura de ciberseguridad de TechCo y establezca procedimientos concretos ante eventos similares.

Entre los hallazgos clave destacan la falta de segmentación de red, la inexistencia de sistemas de monitoreo en tiempo real y la ausencia de un protocolo de respuesta estructurado. El presente documento proporciona recomendaciones detalladas sobre controles preventivos, mecanismos de detección temprana, planes de contención y recuperación, así como directrices para la mejora continua del sistema de gestión de incidentes.

La implementación de este plan permitirá a TechCo responder con mayor eficacia ante futuros ciberataques, proteger sus activos críticos, garantizar la continuidad del negocio y fortalecer la confianza de sus clientes y partes interesadas.

Índice

1. Introducción
2. Identificación
 - 1.1 Activos Críticos Afectados o en Riesgo
 - 1.2 Análisis de Vulnerabilidades y Riesgos
 - 1.3 Evaluación de Riesgos
3. Protección
 - 2.1 Medidas Preventivas Recomendadas
 - 2.2 Formación y Concienciación
 - 2.3 Documentación de Políticas

4. Detección

- 3.1 Métodos y Herramientas de Detección
- 3.2 Alertas Tempranas y Respuesta Inmediata
- 3.3 Procedimiento de Escalado

5. Respuesta

- 4.1 Activación del Plan de Respuesta
- 4.2 Pasos Inmediatos de Respuesta
- 4.3 Roles y Responsabilidades
- 4.4 Gestión de la Comunicación

6. Recuperación

- 5.1 Restauración de Sistemas y Datos
- 5.2 Continuidad del Negocio
- 5.3 Verificación Post-Restauración

7. Mejora Continua

- 6.1 Evaluación del Plan de Respuesta
- 6.2 Análisis de Lecciones Aprendidas
- 6.3 Actualización del Plan

8. Conclusión

Introducción

Este documento presenta un Plan Formal de Respuesta a Incidente de Ransomware para la empresa ficticia TechCo. La elaboración de este plan se basa en el Marco de Ciberseguridad del NIST y tiene como objetivo establecer las políticas, procedimientos y controles necesarios para prevenir, detectar, responder y recuperarse eficazmente de un ataque de ransomware. Asimismo, se busca fortalecer la resiliencia de la organización ante futuras amenazas cibernéticas.

1. Identificación

1.1 Activos Críticos Afectados o en Riesgo

- **Servidor de archivos:** Documentos esenciales para el funcionamiento diario.
- **Base de datos de clientes:** Información personal y financiera sensible.
- **Sistemas de respaldo internos:** Cifrados debido al ataque.
- **Red interna de producción:** Sin segmentación, facilitó la propagación.

1.2 Análisis de Vulnerabilidades y Riesgos

- Vulnerabilidad al phishing.
- Falta de segmentación de red.
- Ausencia de monitoreo en tiempo real.
- Backups accesibles desde la red principal.

1.3 Evaluación de Riesgos

Se clasifica el riesgo según el impacto potencial sobre las operaciones y la confidencialidad de la información. La base de datos de clientes y los respaldos cifrados presentan el mayor nivel de criticidad.

2. Protección

2.1 Medidas Preventivas Recomendadas

- Segmentación de red por funciones (producción, respaldo, administración).
- Uso obligatorio de autenticación multifactor (MFA).
- Políticas de contraseñas seguras.
- Control de acceso basado en roles.
- Mecanismos de respaldo con almacenamiento externo y cifrado.

2.2 Formación y Concienciación

- Entrenamiento regular sobre phishing y amenazas comunes.
- Simulacros de seguridad.
- Revisión anual obligatoria de políticas de seguridad para empleados.

2.3 Documentación de Políticas

- Políticas de gestión de incidentes.

- Manual de ciberseguridad corporativa.
 - Política de backup y restauración.
-

3. Detección

3.1 Métodos y Herramientas de Detección

- SIEM para análisis de eventos.
- Sistemas EDR con análisis de comportamiento.
- Herramientas de monitoreo de integridad de archivos (FIM).

3.2 Alertas Tempranas y Respuesta Inmediata

- Notificaciones de cambios sospechosos.
- Alertas por intentos de acceso no autorizado.
- Informes automatizados de actividad anómala.

3.3 Procedimiento de Escalado

- Registro automático de incidentes.
 - Activación inmediata del CSIRT.
 - Comunicación jerárquica estructurada.
-

4. Respuesta

4.1 Activación del Plan de Respuesta

- Confirmación de incidente.
- Activación del protocolo.
- Aislamiento de sistemas afectados.

4.2 Pasos Inmediatos de Respuesta

- Desconexión de red.
- Revisión de logs.
- Preservación de evidencia digital.

4.3 Roles y Responsabilidades

- **Líder de respuesta:** Coordinación general.

- **Equipo técnico:** Contención y restauración.
- **Área legal:** Evaluación regulatoria.
- **Comunicaciones:** Información interna y externa.

4.4 Gestión de la Comunicación

- Canales seguros.
 - Informes regulares a la dirección.
 - Comunicados a clientes y autoridades.
-

5. Recuperación

5.1 Restauración de Sistemas y Datos

- Verificación de backups no comprometidos.
- Restauración gradual por prioridades.
- Validación de funcionalidad.

5.2 Continuidad del Negocio

- Procedimientos manuales temporales.
- Priorización de servicios críticos.
- Soporte al cliente garantizado.

5.3 Verificación Post-Restauración

- Análisis post-mortem.
 - Escaneos de seguridad.
 - Reintegración de sistemas restaurados.
-

6. Mejora Continua

6.1 Evaluación del Plan de Respuesta

- Revisión de tiempos de respuesta y detección.
- Análisis de eficiencia de medidas aplicadas.

6.2 Análisis de Lecciones Aprendidas

- Reunión post-incidente.

- Documento de hallazgos y mejoras.

6.3 Actualización del Plan

- Revisión semestral.
- Inclusión de nuevas amenazas.
- Pruebas periódicas.

Conclusión

El presente plan busca proporcionar a TechCo una herramienta sólida y estructurada para gestionar incidentes de ransomware con base en el marco NIST. La correcta implementación de sus medidas permitirá reducir significativamente el impacto de futuros incidentes y consolidar una cultura de ciberseguridad proactiva en la organización.